

CLAWDBOT SECURITY CHECKLIST

Production-Ready Security for Your Personal AI Assistant

DISCLAIMER: This checklist is for informational purposes only. Security vulnerabilities listed are **not exhaustive** — new threats emerge constantly. You are solely responsible for securing your deployment. **Do your own due diligence** and consult qualified security professionals before deploying any AI agent in production.

CRITICAL SECURITY FLAWS

VULNERABILITY	RISK	REMEDIATION
Gateway on 0.0.0.0:18789	Anyone can connect	Bind to 127.0.0.1 or Tailscale
DM policy: allowFrom ["*"]	Anyone sends instructions	Use pairing mode or allowlist
Sandbox disabled	Full filesystem access	Set sandbox.mode: "non-main"
Plaintext credentials	Token theft risk	Use env vars + chmod 600
No injection protection	Content controls agent	Wrap in <untrusted> tags
Dangerous commands	System destruction	Configure command blocklist
No network isolation	Lateral movement	Use docker.network=none
Overly permissive tools	Excess permissions	Restrict MCP tools
No audit logging	No forensics	Enable session logging
Weak pairing codes	Brute-force risk	Crypto codes + rate limit

CONFIRMED ATTACK VECTORS

1. Prompt Injection via External Content

- Attacker sends malicious instructions via email, web content, or DM
- Agent executes as if from user (delete emails, exfiltrate data)
- **Fix:** Pairing mode + wrap untrusted content + human-in-the-loop

2. Open Port Discovery

- Scanners (Shodan, Censys) continuously probe for exposed services
- Unauthenticated gateway = anyone can command your agent
- **Fix:** Never expose publicly; use Tailscale Serve or VPN only

3. Token/Credential Abuse

- Compromised agent uses whatever permissions tokens allow
- Full GitHub token = repo wipe; Full Google = email/calendar/drive
- **Fix:** Scope all tokens to minimum required (see next section)

TOKEN SCOPING (LEAST PRIVILEGE)

Never grant full access. Scope tokens to minimum permissions:

SERVICE	AVOID	USE INSTEAD
GitHub	repo (full control)	public_repo or specific repo
Google	Full account	Specific scopes only
Slack	Admin	Post to specific channels
Email	Full mailbox	Send-only or specific folders
Files	Full disk	Specific directories only

ACCESS CONTROL CHECKLIST

■	Bind gateway to 127.0.0.1 (not 0.0.0.0)
■	Set dmPolicy to "pairing" or explicit allowlist
■	Run clawdbot doctor before deployment
■	Use Tailscale Serve for remote access (not Funnel)
■	If using Funnel, require strong password auth
■	Configure gateway.auth_token in environment

SANDBOX & CONTAINMENT

■	Set sandbox.mode: "non-main" for non-primary sessions
■	Run in Docker with non-root user
■	Use read-only mounts for sensitive directories
■	Set docker.network=none for isolation
■	Configure tool allowlist (bash, read, write only)
■	Use ephemeral containers when possible

HUMAN-IN-THE-LOOP POLICY

Require approval for sensitive actions:

ACTION TYPE	EXAMPLES	POLICY
Read-only	Search, read files, list dirs	Auto-approve
Mutating	Write files, run commands	Confirm
Destructive	Delete, send emails, post	Always confirm
Sensitive	Credentials, financial, PII	Always confirm + log

MONITORING & INCIDENT RESPONSE

■	Enable comprehensive session logging
■	Configure rate limiting on gateway
■	Set up alerts for unusual activity
■	Rotate API keys and tokens regularly
■	Document incident response plan
■	Review logs weekly for anomalies

QUICK SECURITY COMMANDS

COMMAND	PURPOSE
<code>clawdbot doctor</code>	Check for risky configs
<code>clawdbot pairing list</code>	See pending requests
<code>clawdbot pairing approve <code></code>	Approve a sender
<code>/elevated off</code>	Disable elevated bash

Agents are powerful. Demo-grade deployments on the open internet are not.